

Análise e Desenvolvimento de Sistemas

Métricas e Auditoria de Software

Sprint 3 — Fundamentos Conceituais

[G1] Introdução à Auditoria de Sistemas

Grupo: G1

Integrantes: _____

Data de entrega: 08/06/2026

1. O que é Auditoria de Sistemas

Auditoria de sistemas é o processo sistemático e independente de coleta e avaliação de evidências sobre os sistemas de informação, a infraestrutura de tecnologia e os processos de uma organização, com o objetivo de verificar se eles operam de forma segura, eficiente, confiável e em conformidade com normas, políticas internas e exigências legais.

De forma geral, auditar significa examinar, com base em evidências objetivas, se algo funciona como deveria. No contexto de TI, isso envolve verificar controles de acesso, integridade dos dados, processos de desenvolvimento e manutenção de software, segurança da informação, continuidade de negócio e aderência a normas como ISO/IEC 27001, COBIT e, em determinados contextos, a Lei Sarbanes-Oxley (SOX).

Os principais objetivos da auditoria de sistemas incluem: garantir a confiabilidade e integridade das informações produzidas pelos sistemas; verificar a eficácia dos controles internos relacionados à TI; identificar riscos de segurança, fraude ou falhas operacionais; e assegurar conformidade com leis, regulamentos e políticas corporativas.

2. Auditoria Interna x Auditoria Externa

A auditoria pode ser classificada quanto à origem da equipe responsável por sua execução, dividindo-se principalmente em auditoria interna e auditoria externa. Embora compartilhem objetivos semelhantes — avaliar controles, riscos e conformidade —, diferem quanto a vínculo, independência, frequência e finalidade.

Critério	Auditoria Interna	Auditoria Externa
Vínculo	Realizada por colaboradores da própria organização (ex.: setor de auditoria interna ou controles internos)	Realizada por empresa ou profissional independente, contratado externamente
Finalidade principal	Apoiar a gestão na melhoria contínua de processos e controles	Emitir parecer independente, muitas vezes para acionistas, órgãos reguladores ou exigências legais
Frequência	Contínua ou periódica, conforme plano anual de auditoria	Geralmente anual ou conforme exigência regulatória/contratual
Independência	Independência funcional dentro da organização	Independência total em relação à organização auditada
Exemplo prático	Equipe de TI interna revisa periodicamente os controles de acesso ao ERP da empresa	Empresa de auditoria externa avalia os controles de TI para emitir parecer sobre as demonstrações financeiras (ex.: exigência da SOX)

Tabela 1 — Comparação entre auditoria interna e auditoria externa.

Em síntese, a auditoria interna funciona como um mecanismo contínuo de autoavaliação e melhoria, enquanto a auditoria externa atua como um mecanismo de validação independente, muitas vezes exigido por lei ou por partes interessadas externas (acionistas, investidores, órgãos reguladores).

3. Especificidades da Auditoria de TI

A auditoria de TI é um ramo especializado da auditoria que foca exclusivamente nos sistemas de informação, na infraestrutura tecnológica e nos processos de governança digital de uma

organização. Diferentemente da auditoria contábil tradicional, que avalia principalmente registros financeiros, a auditoria de TI examina aspectos técnicos e operacionais, exigindo do auditor conhecimento sobre redes, bancos de dados, segurança da informação, desenvolvimento de software e arquitetura de sistemas.

Entre as principais áreas avaliadas em uma auditoria de TI, destacam-se:

- **Segurança da informação:** políticas de controle de acesso, gestão de senhas, criptografia, segregação de funções e proteção contra acessos não autorizados.
- **Infraestrutura e operações:** servidores, redes, backups, planos de continuidade de negócio (BCP) e recuperação de desastres (DRP).
- **Desenvolvimento e manutenção de sistemas:** processos de mudança, testes, homologação e versionamento de código, avaliando se seguem boas práticas e controles adequados ao longo do ciclo de vida do software.
- **Conformidade regulatória:** aderência a normas como ISO/IEC 27001, LGPD, e, em empresas com ações na bolsa norte-americana, a Lei Sarbanes-Oxley (SOX).
- **Governança de TI:** alinhamento entre a estratégia de tecnologia e os objetivos do negócio, frequentemente apoiado em frameworks como o COBIT.

4. Papel e Responsabilidades do Auditor de Sistemas

O auditor de sistemas é o profissional responsável por planejar, executar e reportar os resultados de uma auditoria de TI. Sua atuação exige uma combinação de conhecimentos técnicos (infraestrutura, segurança, desenvolvimento de software) e habilidades analíticas, além de uma postura ética e independente em relação à área avaliada.

As principais responsabilidades do auditor de sistemas incluem:

- Planejar a auditoria, definindo escopo, objetivos, critérios e cronograma de avaliação.
- Coletar evidências por meio de entrevistas, análise de documentos, observação de processos e testes técnicos sobre os sistemas.
- Avaliar a eficácia dos controles internos relacionados à tecnologia, identificando pontos fortes e fragilidades.
- Identificar e classificar riscos relacionados à segurança, conformidade e operação dos sistemas.
- Elaborar relatórios técnicos com os achados da auditoria, incluindo recomendações objetivas para correção de não conformidades.
- Acompanhar a implementação das recomendações em auditorias subsequentes (follow-up).

Um princípio fundamental da atuação do auditor é a independência: o profissional não pode auditar processos pelos quais ele próprio é responsável, garantindo imparcialidade na avaliação. Além disso, espera-se postura ética, sigilo sobre as informações acessadas e objetividade na apresentação dos resultados, mesmo quando estes são desfavoráveis à área auditada.

5. Relação da Auditoria de Sistemas com o SDLC

O SDLC (Software Development Life Cycle, ou Ciclo de Vida de Desenvolvimento de Software) compreende as fases pelas quais um sistema passa, desde o levantamento de requisitos até a operação e manutenção. A auditoria de sistemas se relaciona diretamente com cada uma dessas

fases, atuando como um mecanismo de verificação de qualidade, segurança e conformidade ao longo de todo o ciclo.

Fase do SDLC	Foco da auditoria nesta fase
Levantamento de requisitos	Verificar se requisitos de segurança, controle e conformidade legal foram identificados desde o início.
Projeto / Design	Avaliar se a arquitetura prevê controles de acesso, segregação de funções e trilhas de auditoria (logs).
Desenvolvimento	Verificar boas práticas de codificação, revisão de código, versionamento e segregação entre ambientes de desenvolvimento, teste e produção.
Testes / Homologação	Avaliar evidências de testes funcionais, de segurança e de desempenho antes da liberação para produção.
Implantação / Deploy	Checar se mudanças seguem processo formal de aprovação, com aprovações documentadas e rastreabilidade.
Operação e manutenção	Monitorar incidentes, acessos, backups e atualizações, garantindo continuidade e segurança em produção.

Tabela 2 — Relação entre as fases do SDLC e o foco da auditoria de sistemas em cada uma delas.

Essa integração entre auditoria e SDLC fica cada vez mais evidente em ambientes modernos de desenvolvimento ágil e DevOps, em que práticas como revisão de código obrigatória (pull requests), pipelines de integração e entrega contínua (CI/CD) com verificações automatizadas de segurança (ex.: análise estática de código, SAST) e logs de auditoria automatizados passam a funcionar como controles incorporados ao próprio processo de desenvolvimento, em vez de verificações realizadas apenas ao final.

6. Exemplo Ilustrativo

Cenário: uma empresa de médio porte utiliza um sistema ERP para controlar estoque, vendas e financeiro. Uma auditoria interna de sistemas é realizada anualmente.

Etapa 1 — Planejamento: o auditor define que o escopo da auditoria deste ano inclui os controles de acesso ao módulo financeiro do ERP.

Etapa 2 — Coleta de evidências: o auditor solicita a lista de usuários com acesso ao módulo financeiro, realiza entrevistas com a equipe de TI e observa, na prática, como novos acessos são concedidos e revogados.

Etapa 3 — Avaliação: verifica-se que três ex-funcionários ainda possuem acesso ativo ao sistema, configurando uma falha no controle de revogação de acessos — um achado de auditoria.

Etapa 4 — Relatório e recomendação: o auditor registra o achado no relatório, classifica o risco como alto (acesso indevido a dados financeiros) e recomenda a criação de um processo formal de revogação imediata de acessos no desligamento de colaboradores, integrado ao processo de RH.

Esse exemplo simples ilustra como a auditoria de sistemas atua de forma prática: não se limita a apontar problemas, mas busca compreender causas, avaliar riscos associados e propor melhorias concretas nos processos e controles da organização.

Referências

- ABNT NBR ISO/IEC 27001:2022 — Tecnologia da informação — Técnicas de segurança — Sistemas de gestão de segurança da informação — Requisitos.
- ISACA. COBIT 2019 Framework: Governance and Management Objectives. ISACA, 2019.
- PRESSMAN, R. S.; MAXIM, B. R. Engenharia de Software: Uma Abordagem Profissional. 8. ed. Porto Alegre: AMGH, 2016.
- BRASIL. Sarbanes-Oxley Act (SOX), 2002 — referência internacional para controles internos de TI em empresas com ações negociadas nos EUA.